

Control Objective 1: Wire Transfer Authorization

Ensure all wire transfers above \$10,000 require dual authorization from two independent approvers. The first approver verifies the request details and supporting documentation. The second approver independently confirms the recipient information and transaction purpose. Both approvers must be at the manager level or above and cannot be the same individual. All wire transfer requests must be submitted through the approved electronic system and include complete originator and beneficiary information. Manual or verbal wire transfer instructions are prohibited.

Testing approach: Select a random sample of 25 wire transfers above the threshold from the past quarter. For each transfer, verify that two distinct approver signatures are present on the authorization form and that both approvers hold the required management level. Document any exceptions found.

Control Objective 2: Account Opening Verification

All new account openings must include verification of customer identity using two forms of government-issued identification. The verification must be documented in the customer file and reviewed by a supervisor within 24 hours of account creation. Enhanced due diligence must be performed for high-risk customers, politically exposed persons, and non-resident accounts. The customer risk rating must be assigned at account opening and reviewed annually thereafter.

Testing approach: Select 20 recently opened accounts. Verify that the customer file contains copies of two forms of identification and that the supervisor review sign-off is dated within one business day. Check that risk ratings are assigned and appropriate for the customer profile.

Control Objective 3: Transaction Monitoring

The automated transaction monitoring system must flag all transactions exceeding \$50,000 for manual review. Flagged transactions must be reviewed and dispositioned within 48 hours. All reviews must be documented in the case management system with a clear rationale for the disposition decision. Suspicious activity reports must be filed within five business days of determination. The monitoring thresholds must be reviewed and calibrated quarterly to ensure effectiveness.

Testing approach: Review system configuration to confirm the \$50,000 threshold is active. Select 30 flagged transactions and verify timely review and proper documentation in the case management system. Verify that all suspicious activity reports were filed within the required timeframe.

Control Objective 4: Segregation of Duties

No single individual may both initiate and approve a financial transaction. The system must enforce this separation through role-based access controls. Any attempts to circumvent this control must be logged and reported to the compliance team within 24 hours. Access roles must be reviewed quarterly to ensure continued appropriateness. Temporary role assignments for coverage purposes must be pre-approved and time-limited.

Testing approach: Review user access profiles for all transaction processors. Verify that no user has both initiator and approver roles. Test the system by attempting same-user initiation and approval. Review the exception log for any circumvention attempts during the review period.

Control Objective 5: Data Backup and Recovery

All critical financial data must be backed up daily with encrypted backups stored in a geographically separate facility. Recovery testing must be performed quarterly to verify data integrity and recovery procedures. Backup completion must be verified by automated monitoring with alerts for any failures. The recovery point objective is 24 hours and the recovery time objective is 4 hours for critical systems.

Testing approach: Review backup logs for the past 90 days. Verify daily backup completion and encryption status. Review the most recent quarterly recovery test results and confirm successful data restoration within the defined recovery time objective.

Control Objective 6: Access Review

User access to financial systems must be reviewed quarterly by department managers. Any access that is no longer required must be revoked within five business days of the review. All reviews must be documented and retained for audit purposes. Privileged access accounts must be reviewed monthly by the IT Security team. Service accounts must be inventoried and their access justified semi-annually.

Testing approach: Obtain the most recent quarterly access review report. Verify that all users were reviewed and that identified revocations were processed within the required timeframe. Check privileged account reviews.

Control Testing Summary

Control ID	Description	Frequency	Owner	Last Tested
CTL-101	Control test procedure 1	Semi-annually	Risk Manager	2025-01-27
CTL-102	Control test procedure 2	Monthly	Compliance Lead	2025-05-27
CTL-103	Control test procedure 3	Annually	Audit Director	2025-05-01
CTL-104	Control test procedure 4	Semi-annually	Operations VP	2025-04-23
CTL-105	Control test procedure 5	Annually	IT Security	2025-02-17
CTL-106	Control test procedure 6	Monthly	Branch Manager	2025-03-06
CTL-107	Control test procedure 7	Semi-annually	Treasury Head	2025-01-30
CTL-108	Control test procedure 8	Monthly	CFO	2025-04-13

Control Objective 7: Vendor Risk Management

All third-party vendors with access to customer data or financial systems must undergo a risk assessment prior to onboarding and annually thereafter. Vendor contracts must include data protection clauses, right-to-audit provisions, and incident notification requirements. High-risk vendors must provide SOC 2 Type II reports or equivalent assurance documentation. Vendor performance must be monitored against defined service levels.

Testing approach: Select 15 active vendors with data access. Verify that initial and annual risk assessments are on file. Review contracts for required clauses. For high-risk vendors, confirm receipt and review of SOC 2 reports or equivalent documentation.

Control Objective 8: Incident Response

All security incidents must be reported to the IT Security team within one hour of detection. The incident response plan must be activated for all confirmed incidents. Post-incident reviews must be conducted within five business days and lessons learned must be documented and communicated to relevant stakeholders. The incident response plan must be tested annually through tabletop exercises or simulations.

Testing approach: Review the incident log for the past six months. Verify that all incidents were reported within the required timeframe. Select five resolved incidents and verify that post-incident reviews were completed and lessons learned were documented and distributed.

Control Objective 9: Change Management

All changes to production financial systems must follow the change management process including impact assessment, testing, approval, and documentation. Emergency changes must be retrospectively approved within 48 hours. All changes must be tracked in the change management system with a complete audit trail. Rollback procedures must be documented for all changes.

Testing approach: Select 20 recent production changes. Verify that each change followed the required process including appropriate approvals and testing documentation. Review emergency changes for retrospective approval. Verify rollback procedures are documented.

Control Objective 10: Regulatory Compliance Monitoring

The compliance team must maintain a regulatory inventory covering all applicable federal and provincial regulations. Regulatory changes must be assessed for impact within 30 days of publication. Required policy and procedure updates must be implemented within 90 days. Compliance training must be completed by all staff annually.

Testing approach: Review the regulatory inventory for completeness. Select five recent regulatory changes and verify timely impact assessment and implementation of required updates. Review training completion records to confirm all staff have completed annual compliance training.

SUMMARY OF FINDINGS

SUMMARY OF FINDINGS: Based on the testing procedures performed, all ten control objectives were found to be operating effectively during the review period. No material exceptions were identified. Two minor observations were noted regarding documentation timeliness and have been communicated to the responsible department heads for remediation. The overall control environment is assessed as satisfactory with a low residual risk rating. The next scheduled review will be conducted in the following quarter. Management has agreed to address the minor observations within 30 days and will provide evidence of remediation to the internal audit team for verification.